

Vanteloq Plaid privacy and security evidence

CONDITIONAL

Plaid production remains blocked until Cloudflare rejects TLS below 1.2 and legal review is completed.

Evidence version: 1.0

Prepared: August 11, 2026

Application: Vanteloq at <https://vanteloq.com>

Organization: LexEdge Consulting, operating as Vanteloq

Review result: Proceed with conditions; Plaid production access must remain disabled until the TLS blocker and legal review are complete.

Executive statement

Vanteloq has implemented a consent-first, read-only Plaid flow. An authenticated and MFA-confirmed workspace user must actively accept a versioned financial-data notice before the server creates a Plaid Link token. The server records the accepted data categories, purposes, policy version, notice version, workspace, actor identifier, and time. The public token exchange is bound to that fresh server-side consent record.

Plaid credentials are application-encrypted with AES-GCM before storage and are separated from routine connection metadata. The Cloudflare D1 managed database also encrypts stored data at rest. Disconnecting calls Plaid item revocation, deletes local encrypted credentials, stops scheduled access, and withdraws active consent. A separate owner-only workflow deletes unreviewed imports and de-identifies provider fields in approved, reconciled, or posted accounting records that must remain.

This document is technical evidence, not a legal opinion or a statement that every privacy law applies in the same way. Qualified Alberta/Canadian counsel should review the policy, customer contracts, cross-border notices, and retention periods before production launch.

Control matrix

Requirement	Implementation	Evidence	Status
Meaningful consent before collection, processing, and storage	Separate unselected authorization checkbox before Link; exact data and purposes shown; Plaid Link provides provider/account consent	app/plaid-link-button.tsx, domain/privacy-controls.ts	Implemented and tested
Durable consent evidence	Tenant/user/provider/version/time/categories/purposes recorded server-side	integration_consents table; server/privacy.ts; migration 0024_thick_mysterio.sql	Implemented and tested
Consent bound to connection	Link-token endpoint records consent; exchange endpoint rejects missing, stale, wrong-user, or wrong-workspace consent	Plaid link-token and exchange API routes	Implemented and tested
Data minimization	Plaid Transactions product plus Balance data; Canadian institutions; read-only disclosure; pseudonymous Plaid client user ID	server/integrations/plaid.ts and Plaid tests	Implemented and tested
Encryption at rest	Cloudflare D1 platform encryption; additional AES-GCM encryption for access token and item ID; key held in hosted environment	server/integrations/plaid.ts; Cloudflare D1 data-security documentation	Implemented and tested in code
Encryption in transit	HTTPS, HSTS, CSP upgrade-insecure-requests; target minimum is TLS 1.2	worker/index.ts; live curl protocol check	Blocked: live edge currently accepts TLS 1.1
Access control	Supabase identity, confirmed AAL2/TOTP, tenant membership, RBAC permission finance.connections, same-origin checks, bounded payloads, rate limits	authorization/API/permission modules and protected routes	Implemented and tested
Revocation	Plaid /item/remove, encrypted credential deletion, sync blocked, consent withdrawn	disconnect route and Plaid integration module	Implemented and tested
Data deletion	Owner-only, AAL2, exact confirmation, three attempts/day, atomic deletion/de-identification batch, audit result	delete-data route; Plaid integration module; retention policy	Implemented and tested
Retention governance	Versioned matrix, quarterly operating review, annual renewal, scoped legal holds, failure handling	docs/DATA_RETENTION.md	Policy implemented; review is procedural
Public privacy notice	Public policy identifies Plaid, fields, purposes, cross-border processing, withdrawal, retention, deletion, safeguards, and contacts	app/privacy/page.tsx; /privacy	Implemented; legal review required
Auditability	Consent, authorization, connection, disconnect, and deletion events record actor/workspace/request metadata without raw bank data	server/audit.ts and Plaid routes	Implemented and tested

Consumer consent flow

- 1 An authenticated user with `finance.connections` permission opens the Plaid card.
- 2 Vanteloq displays the versioned financial-data authorization. Nothing is preselected.
- 3 The notice lists institution/account names, type, masked number, balances, transactions, provider identifiers, purposes, read-only limitation, withdrawal, and retention consequences.
- 4 After the user checks the authorization, the browser sends the exact notice and privacy-policy versions to the same-origin server.
- 5 The server confirms Supabase identity, AAL2, tenant membership, role/permission, rate limit, and policy version; it then writes the consent record.
- 6 The server creates the Plaid Link token. Plaid Link separately presents the supported institution, eligible accounts, provider permission, and data-transparency messaging.

- 7 Public-token exchange succeeds only when the consent-record ID belongs to the same actor/workspace, is accepted, matches current versions, and is no more than 30 minutes old.

Plaid data inventory and purpose

Data	Purpose	Storage
Institution/account name, type, subtype, mask, currency	Identify the selected business account and support reconciliation	Tenant-scoped D1 bank/financial-account records
Current/available balance and credit	Cash position and liquidity context	Tenant-scoped D1 bank-account record
Transaction date, amount, description, status, currency	Bookkeeping review and reconciliation	Tenant-scoped D1 financial-transaction record, initially pending approval
Plaid item/account identifiers and cursor	Idempotent synchronization and connection support	Metadata separated from token; cleared by deletion workflow
Plaid access token and item credential	Authorized provider API access	Additional AES-GCM encrypted ciphertext in isolated secret table
Consent versions, categories, purposes, actor/workspace, time	Authorization evidence and complaint handling	Tenant-scoped consent table; no bank credentials

Vanteloq does not receive the online-banking password entered in Plaid Link, does not use Plaid data for advertising, and does not enable payments or money movement in this connection.

Encryption evidence

At rest

- Provider credentials are encrypted in the application with Web Crypto AES-GCM using a random 96-bit IV for every value. Stored form is versioned ciphertext; the encryption key is a hosted secret and is not selected by connection-status queries.
- Cloudflare documents that D1 database objects and metadata are encrypted at rest automatically with AES-256-GCM.
- Supabase authentication data is handled by the managed authentication service and accessed by HTTPS APIs. Vanteloq does not copy raw passwords into its database.

In transit

- Vanteloq redirects the legacy preview hostname to the canonical HTTPS origin.
- The Worker sets one-year HSTS and upgrade-insecure-requests in the Content Security Policy.
- A protocol check performed August 11, 2026 confirmed TLS 1.2 succeeds but also found TLS 1.1 succeeds. Cloudflare Minimum TLS must be changed to 1.2 and both tests rerun before this control is marked complete or Plaid production access is enabled.

Required release evidence:

TLS 1.1 maximum -> handshake rejected
TLS 1.2 exact -> request succeeds

Deletion and retention behavior

- Disconnect first: revoke the Plaid item, remove encrypted credentials, block promotion/sync, and withdraw consent.
- Delete unreviewed data: the protected deletion batch removes Plaid transactions that are not approved, reconciled, or journal-posted.

- Preserve ledger integrity: if a transaction is approved, reconciled, or posted, the workflow removes Plaid descriptions, pending links, and external identifiers; the minimal amount/date/currency/accounting relationship remains.
- Remove provider metadata: bank-account rows and connection identifiers are deleted; related financial accounts are archived and de-identified.
- Record the result: the audit event stores counts and limitations, not the deleted values.
- Review quarterly and renew this policy annually or after material product, provider, infrastructure, jurisdiction, or legal changes.

The detailed schedule and exception process are in docs/DATA_RETENTION.md.

Public policy and consumer requests

The public policy is deployed at <https://vanteloq.com/privacy>. It is linked from the pre-Link authorization notice and identifies the Privacy Officer, Plaid data categories and purposes, service-provider processing, cross-border risk, withdrawal, deletion limitations, safeguards, and regulator contacts.

Verified privacy requests are sent to the Privacy Officer address in the policy. Identity and authority must be verified before exporting, correcting, or deleting workspace financial data. If a customer controls the information, the request may need to be coordinated with that customer.

Test evidence

The following checks passed on August 11, 2026:

- TypeScript typecheck.
- Seven Plaid integration/privacy tests.
- Twenty-eight interaction, legal-policy, and accessibility-integrity tests.
- Incremental migration file generated for the consent table and deletion timestamp.
- Three local Miniflare migration, tenant-isolation, and end-to-end integration flow tests.

Remaining launch conditions

- 1 Sign in to the Cloudflare account for vanteloq.com, set SSL/TLS -> Edge Certificates -> Minimum TLS Version to 1.2, and rerun the negative/positive protocol tests.
- 2 Obtain qualified Alberta/Canadian privacy counsel review of the public policy, retention periods, cross-border disclosures, customer/controller terms, and response procedure.
- 3 Keep Plaid in sandbox/development until Plaid approves production access and the conditions above are recorded as complete.
- 4 Capture a clean MFA challenge screenshot for the Plaid questionnaire. Do not submit the QR enrollment screen or any setup secret.

Authoritative references

- Office of the Privacy Commissioner of Canada, meaningful consent: https://www.priv.gc.ca/en/privacy-topics/privacy-laws-in-canada/the-personal-information-protection-and-electronic-documents-act-pipeda/p_principle/principles/p_consent/
- Office of the Privacy Commissioner of Canada, limiting use, disclosure, and retention: https://www.priv.gc.ca/en/privacy-topics/privacy-laws-in-canada/the-personal-information-protection-and-electronic-documents-act-pipeda/p_principle/principles/p_use/

- Government of Alberta, PIPA and organization responsibilities: <https://www.alberta.ca/personal-information-protection-act> and <https://www.alberta.ca/organization-responsibilities-for-protecting-personal-information.aspx>
- Cloudflare D1 data security: <https://developers.cloudflare.com/d1/reference/data-security/>
- Cloudflare Minimum TLS Version: <https://developers.cloudflare.com/ssl/edge-certificates/additional-options/minimum-tls/>
- Plaid Link data-transparency messaging: <https://plaid.com/docs/link/data-transparency-messaging-migration-guide/>
- Plaid Link customization and consent pane: <https://plaid.com/docs/link/customization/>
- Supabase database security and SSL enforcement: <https://supabase.com/docs/guides/database/secure-data> and <https://supabase.com/docs/guides/platform/ssl-enforcement>